

FedRAMP-inspired Rev. 5 (Low-Baseline)

Chris George Paikayil

Status: Implemented (Cloudformation baseline)

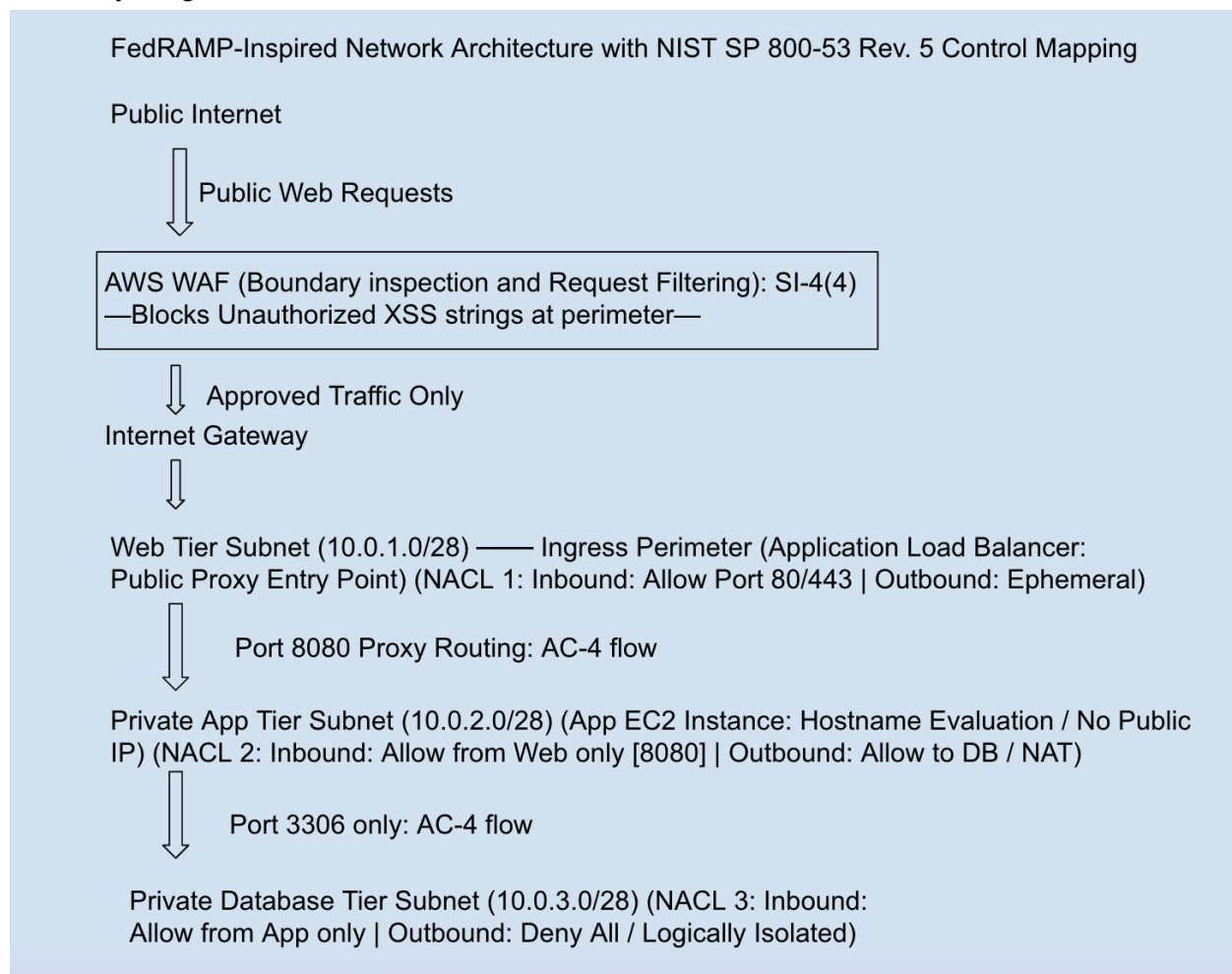
Region: US East (Ohio)

Section one: System Identification and Boundary

Service model: Infrastructure as code (IAC) as the network baseline

Network Boundary Details: The environment boundary is restricted only to the Virtual Private Cloud (VPC) using 10.0.0.0/16 CIDR block.

Boundary Diagram:



Configuration Metadata Standardization: All CloudFormation stack resources are tagged with Compliance: FedRAMP-Inspired to reflect the intent of this baseline. The label "FedRAMP-Inspired" is used deliberately — this environment is engineered to align with FedRAMP Rev. 5 Low controls but has not undergone formal third-party assessment (3PAO) or

received an official FedRAMP authorization. The compliance tags serve as internal metadata for audit traceability and are consistent across all deployed stacks.

Section two: Authorized services, ports and protocols

Inbound https	443	tcp	Allows public, encrypted web traffic from the internet to web tier.
---------------	-----	-----	---

Inbound http	80	tcp	Accepted at ALB perimeter for redirect to HTTPS :443 only; not forwarded to any backend resource
NACL 1 outbound egress	1024-65535	TCP	Standard Ephemeral port range, handles return traffic and does not authorize web - app traffic.

Web-to-app link	8080	TCP	Allows public web tier to forward filtered requests across the boundary to priv app.
App-to-DB link	3306	TCP	Allows priv app tier to give DB tier queries across the isolated boundary.
All other traffic	ANY	ANY	Explicitly deny all

Section three: NIST SP 800-53 Control Implementation Statements (SSP Appendix A)

SC-7: Boundary protection

Implementation status: Implemented in the baseline configuration via IaC

Responsible role: Cloud security engineer

Implementation Narrative: The system is strictly bound within the AWS VPC structure. All compute resources are isolated from the public internet inside private subnets with no public IP addresses assigned. The architecture enforces a dual-layer boundary protection model: at the network layer, stateless NACLs are attached to each subnet segment and explicitly filter all inbound and outbound traffic before it reaches any compute resource; at the application layer, an AWS WAF Web ACL is positioned in front of the public-facing Application Load Balancer to inspect and filter Layer 7 HTTP/HTTPS traffic for web application attack patterns including XSS and SQLi. All external traffic enters the environment exclusively through the ALB perimeter on HTTPS port 443.

SC-7(3): Access Points

Implementation status: Pre-provisioned/dormant

Responsible role: Cloud security engineer

Implementation Narrative: The system limits external exposure to a single controlled ingress point: the Application Load Balancer operating on HTTPS port 443. The Internet Gateway defined in igw.json serves exclusively as the upstream gateway for ALB traffic and does not provide any instance with a direct internet path. Public IP auto-assignment is disabled at the CloudFormation resource level (MapPublicIpOnLaunch: false) on all subnets, including the public-designated web tier — meaning no compute instance is directly reachable from the internet regardless of IGW or route table configuration. All live traffic enters the environment exclusively through the ALB perimeter.

AC-3: Access Enforcement

Implementation status: Implemented in the baseline configuration via IaC

Responsible role: Cloud security engineer

Implementation Narrative: System enforces approved authorizations for logical access to network enclaves and resources. The NACLs are enforced at the network layer (layer 3) explicitly, this governs communication between active and passive network subjects and prevents unauthorized access.

AC-4: Information Flow Enforcement

Implementation status: Implemented in the baseline configuration via IaC

Responsible role: Cloud security engineer

Implementation Narrative: Information flow is strictly regulated within the tiered subnets. Enforces organized routing policies (Web - app - DB) where only authorized traffic goes in a unidirectional pathway. This is in alignment with SC-7 (Boundary protection).

AC-6: Least Privilege

Implementation status: Implemented in the baseline configuration via IaC

Responsible role: Cloud security engineer / Identity admin

Implementation Narrative: The system enforces least privilege across both the network and identity layers. At the network layer, NACLs use granular CIDR blocks scoped to specific subnet ranges rather than VPC-wide ranges, and Security Groups use Security Group ID chaining rather than hardcoded CIDRs — ensuring only specific, named resources can communicate with each other. For example, the application tier Security Group accepts inbound traffic exclusively from the ALB Security Group ID, and the database tier accepts inbound traffic exclusively from the application tier Security Group ID. At the identity layer, all engineering and deployment operations are restricted to a scoped, non-root IAM user (sandbox-admin), preventing the use of unnecessary system privileges.

IA-2: Identification and authentication

Implementation status: Implemented in the baseline configuration

Responsible role: Identity admin

Implementation Narrative: The system uniquely identifies and authenticates all users who perform engineering or deployment tasks. All CLI operations and CloudFormation are strictly tied to a specific non root IAM user account (sandbox-admin), ensuring that every and all automated processes are explicitly associated with a valid ID.

IA-2(1): Multi-Factor Authentication to Privileged Accounts

Implementation status: Implemented in the baseline configuration

Responsible role: Identity admin

Implementation Narrative: The system has an MFA for all privileged accounts. Any user that possesses escalated privileges like the root user must successfully authenticate with an authenticator app before being authorized to access the account.

CM-2: Baseline Configuration

Implementation status: Implemented in the baseline configuration via IaC

Responsible role: Cloud security engineer / DevOps lead

Implementation Narrative: The system baseline configuration is formally established, documented, and maintained via infrastructure as code. All components — VPC, Internet Gateway, three tiered subnets, per-subnet NACLs, Security Groups, Application Load Balancer, WAF Web ACL, and EC2 compute — are explicitly defined in modular JSON CloudFormation templates. These templates serve as immutable, repeatable configuration artifacts that can be redeployed consistently across environment stages.

SI-4: Information System Monitoring

Implementation status: Implemented

Responsible role: Cloud Security Engineer / DevSecOps Engineer

Implementation narrative: To monitor and filter the traffic for inbound requests, an AWS WAF Web ACL is set in front of the public-facing Application Load Balancer (ALB). The WAF looks at the inbound traffic HTTP/HTTPS web requests against a defined rule set to detect and filter anomalous layer-7 traffic before it reaches the internal compute tier. The Web ACL is configured with the vendor-managed AWSManagedRulesCommonRuleSet, which tests request components such as headers, query strings, and body content for patterns that are associated with web application attacks. Such as Cross-Site Scripting (XSS) and SQL Injection (SQLi). The enforcement mechanism was validated by sending a test <script> request through the public URL, which was seen as unauthorized and returned a 403 Forbidden response at the perimeter.

Section four: Plan of Action and Milestones (POA&M)

Item 1: Outbound patch management and Dependency Updates

Control: SC-7 (boundary protection) / SI-2 (Flaw Remediation)

Status: Closed – Resolved

Deficiency description: The private application and database tiers are configured with restrictive network boundaries that prevent outbound access to external update repositories. As a result, operating system and application patching cannot be performed through standard internet-based update mechanisms.

Resolution: A managed AWS NAT Gateway was provisioned in the public subnet (routetable.json) with an associated Elastic IP. The private route table was updated to direct 0.0.0.0/0 outbound traffic through the NAT Gateway, permitting one-way outbound internet access from the private app tier for patching and dependency retrieval while preserving full inbound isolation. The database tier retains no NAT egress and remains fully air-gapped by design.

Item 2: Secure remote command line access.

Control: AC-17 (Remote access) / AC-6 (Least privilege)

Status: Closed – Resolved

Deficiency description: The environment currently lacks a secure remote administration method for command-line access to compute instances. Traditional inbound SSH/RDP access is not enabled, which limits troubleshooting, log review, and operational maintenance while preserving boundary isolation.

Resolution:: AWS Systems Manager Session Manager was implemented for remote administration, providing encrypted command-line access with IAM-based authorization and full audit logging — without requiring public IP addresses, open inbound ports, or bastion host infrastructure. Successful remote access was validated by executing a non-interactive SSM command document against the private EC2 instance through the CLI.